



Solicitante: I.T.S - Instituto Tecnológico Superior Arias Balparda.

Nombre Fantasía, de la nueva empresa: Lidenskap

Grupo: 3ºMK

Turno: Matutino

Unidad Curricular: Tecnologías de la información

Nombres de los integrantes del grupo: Sofía Prieto, Federico Rodríguez, Gastón Visos, Joaquín Villena.

Fecha de entrega: 27/07/2026

**Instituto Tecnológico Superior Arias Balparda.
Blvr. José Batlle y Ordóñez 3570 esq. Gral. Flores – Montevideo.**



ANEP



UTU

DIRECCIÓN GENERAL
DE EDUCACIÓN
TÉCNICO PROFESIONAL



1. Descripción del sistema.....	3
2. Identificación de amenazas específicas para su sistema.....	4
Amenaza.....	4
Activo afectado:.....	4
Ataque/.....	4
Descripción.....	4
Posible consecuencia.....	4
3. Posibles vulnerabilidades en infraestructura.....	6
4. Controles de acceso y roles de usuarios.....	8
Roles (aplicación).....	8
Controles a implementar sobre esta capa:.....	8
Usuarios del sistema operativo (servidor):.....	8
5. Definición de políticas de contraseñas.....	9
6. Políticas y medidas de seguridad.....	10
7. Matriz de análisis de seguridad.....	11

Primera Entrega – Ciberseguridad

1. Descripción del sistema

- ¿Cuál es el objetivo del sistema?

SGDM es una aplicación web que tiene como objetivo brindar una plataforma para la organización, administración y seguimiento de torneos deportivos, gestionando inscripciones y la publicación de puntajes en tiempo real durante las competencias, para que tanto como los organizadores y el público puedan seguir su desarrollo

- ¿Quiénes serán sus usuarios?

Los usuarios a nivel de aplicación se dividen en : Administrador general(que gestiona el sistema en su totalidad),Organizador de torneos (que gestiona los torneos que tiene asignados, las inscripciones y la carga de resultados), Participante (incluye a juveniles) y Usuarios publicos (que consultan calendarios, rankings y resultados sin necesidad de registrarse).

- ¿Qué información almacenará?

El sistema almacenará datos personales de los participantes (nombre, edad/categoría, datos de contacto), credenciales de acceso de los usuarios registrados, información de los torneos (fechas, categorías, equipos, asignación de organizadores), resultados y puntajes de las competencias, y un registro de auditoría de las acciones administrativas realizadas dentro del sistema. Ya que que está manejando información de menores de edad y resultados oficiales de competencias, la confidencialidad e integridad de estos datos son especialmente sensibles.



2. Identificación de amenazas específicas para su sistema

SGDM es una aplicación web de gestión deportiva que administra inscripciones de participantes (incluyendo menores de edad en competencias escolares/juveniles) y publicación de puntajes en tiempo real durante los torneos. Estas características exponen superficies de ataque críticas propias del sector deportivo digital.

enumeramos seis amenazas específicas, su método de ataque y su posible efecto en la continuidad del negocio y la reputación de las ligas deportivas que las utilizan:

Amenaza	Activo afectado:	Ataque/ Descripción	Posible consecuencia
Inyección SQL (SQL Injection)	Base de datos del sistema	Manipulación de campos de formularios (inscripción de participantes, login, carga de resultados) para insertar sentencias SQL no autorizadas y leer, modificar o borrar datos de la base	Filtración de datos personales de participantes (incluyendo menores de edad), alteración de resultados oficiales y pérdida total de confianza de las ligas usuarias en la integridad del sistema.
Cross-Site Scripting (XSS)	Interfaz pública y sesiones de los administradores u organizadores.	scripts maliciosos en campos públicos (nombre de equipo, comentarios de perfil, nombre de torneo) que se ejecutan en el navegador de otros usuarios al visualizar calendarios o rankings públicos.	Robo de sesiones de organizadores o administradores, desfiguración de la interfaz pública y daño reputacional frente a las ligas y espectadores.



Amenaza	Activo afectado:	Ataque/ Descripción	Posible consecuencia
Inyección SQL (SQL Injection)	Base de datos del sistema	Manipulación de campos de formularios (inscripción de participantes, login, carga de resultados) para insertar sentencias SQL no autorizadas y leer, modificar o borrar datos de la base	Filtración de datos personales de participantes (incluyendo menores de edad), alteración de resultados oficiales y pérdida total de confianza de las ligas usuarias en la integridad del sistema.
Denegación de Servicio (DoS / DDoS)	Servidor web y disponibilidad de la plataforma.	Saturación del servidor mediante peticiones masivas, especialmente en momentos críticos como la publicación de resultados en tiempo real de un torneo en curso.	Interrupción del servicio durante eventos deportivos en vivo, incumplimiento de la disponibilidad prometida a los organizadores y pérdida de credibilidad comercial.
Manipulación de datos en tránsito	Comunicaciones de red entre los usuarios y el servidor.	interceptación de comunicaciones no cifradas entre el cliente y el servidor para alterar puntajes, resultados o datos de inscripción mientras viajan por la red.	alteración de resultados oficiales de competencias, generando reclamos, descalificaciones injustas y pérdida de la validez deportiva del torneo.
Automatización de registros falsos (Bots / Credential Stuffing)	cuenta de usuario, los sistemas de autenticación y la base de datos de clientes.	Uso de scripts automatizados para crear cuentas falsas, saturar cupos de inscripción o probar combinaciones de credenciales robadas de otros sitios contra el login del sistema.	Cupos de torneos ocupados por participantes ficticios, datos estadísticos corruptos y posible acceso no autorizado a cuentas reales de participantes u organizadores.



Amenaza	Activo afectado:	Ataque/ Descripción	Posible consecuencia
Inyección SQL (SQL Injection)	Base de datos del sistema	Manipulación de campos de formularios (inscripción de participantes, login, carga de resultados) para insertar sentencias SQL no autorizadas y leer, modificar o borrar datos de la base	Filtración de datos personales de participantes (incluyendo menores de edad), alteración de resultados oficiales y pérdida total de confianza de las ligas usuarias en la integridad del sistema.
Broken Access Control	Funciones y permisos del sistema.	fallas en la verificación de permisos (por ejemplo, modificar el ID de un recurso en la URL o en una petición API) para que un Participante acceda a funciones reservadas a un Organizador o Administrador.	Modificación no autorizada de resultados, torneos o configuraciones críticas, comprometiendo la imparcialidad de las competencias gestionadas.

Estas amenazas son priorizadas ya que atacan directamente los activos más sensibles de SGDM: como los datos personales de adultos y menores, la integridad de los resultados deportivos publicados y la disponibilidad del servicio durante eventos en vivo, donde una caída del sistema puede tener un costo en la reputación inmediato para las ligas que confían en la plataforma.



3. Posibles vulnerabilidades en infraestructura

Con respecto al servidor, se utiliza AlmaLinux instalado sobre una máquina virtual en Proxmox. Actualmente el acceso por SSH no cuenta con protección contra ataques de fuerza bruta, como podría ser Fail2Ban o algún sistema de detección de intrusos. Además, todavía no se implementó HTTPS/TLS, por lo que la información que se transmite viaja en texto plano. Al utilizar la versión Minimal de AlmaLinux se reduce la cantidad de servicios instalados y, por lo tanto, la superficie de ataque; sin embargo, cualquier herramienta de monitoreo o diagnóstico debe instalarse manualmente mediante DNF cuando sea necesaria. También falta configurar la rotación de logs, lo que podría provocar la pérdida de registros importantes o incluso ocupar demasiado espacio en el disco. Por otra parte, la máquina virtual dispone únicamente de 1 vCPU y 4 GB de memoria RAM, por lo que tiene un margen reducido para soportar aumentos de carga o ataques que consuman recursos.

En cuanto a la base de datos, MariaDB mantiene una configuración inicial pensada para equipos con mayores recursos, por lo que sería recomendable ajustar parámetros como los buffers y revisar la configuración de los usuarios. Además, los usuarios de la base de datos todavía no están separados según sus funciones, y sigue existiendo el riesgo de sufrir ataques de inyección SQL. Para disminuir este riesgo, es recomendable utilizar prepared statements en todas las consultas realizadas por la aplicación.

Otro aspecto a tener en cuenta es que Apache, PHP y MariaDB están instalados en la misma máquina virtual dentro de la red interna. Esto implica que, si un atacante consigue vulnerar el servidor web, también tendría la posibilidad de acceder de forma directa a la base de datos. Además, el servidor dispone de un solo adaptador de red, por lo que una falla en este componente dejaría al sistema sin conexión. A esto se suma que el servidor se conecta a la red de la UTU, la cual es compartida por estudiantes y funcionarios, sin una segmentación que separe el tráfico correspondiente al proyecto del resto de la red institucional. Al encontrarse todos los equipos dentro del mismo dominio de red, un dispositivo comprometido en otra área de la institución podría intentar acceder al servidor o incluso interceptar el tráfico dirigido hacia él. Por esta razón, sería conveniente verificar si existe una VLAN destinada exclusivamente al proyecto, de manera que el tráfico relacionado con la administración y el desarrollo permanezca aislado del resto de la infraestructura de la institución.

Por último, actualmente no se cuenta con un sistema de copias de seguridad para el servidor ni para la base de datos. En consecuencia, ante un problema de hardware, un ataque de ransomware o la eliminación accidental de información, los datos de participantes, torneos y resultados podrían perderse de forma definitiva, sin posibilidad de recuperarlos.



4. Controles de acceso y roles de usuarios

Es importante distinguir, que existen dos capas de usuarios completamente independientes en este proyecto: los roles funcionales de la aplicación web (definidos en Ingeniería de Software) y las cuentas del sistema operativo del servidor (definidas en Administración de Sistemas Operativos). Ningún usuario del sistema operativo representa a un rol de la aplicación, ni viceversa.

Roles (aplicación)

ROL-01 Administrador general: Nivel 1, control total, sin restricciones operativas sobre todo el sistema.

ROL-02 Organizador de torneo: Nivel 2, acceso restringido únicamente a los torneos que tiene asignados.

ROL-03 Participante: Nivel 3, solo lectura, no modifica resultados ni torneos, solo su información.

ROL-04 Usuario público: Nivel 4, consulta pública sin autenticación, no modifica información.

Controles a implementar sobre esta capa:

Autorización verificada en el backend, nunca únicamente ocultando botones en el frontend. Un Organizador de torneo solo puede operar sobre torneos donde figura asignado.

Renovación del identificador de sesión al iniciar sesión, para evitar que alguien "robe" una sesión ya autenticada.

Registro de auditoría de acciones administrativas, guardar un historial de quién hizo cada cambio importante y cuándo.

Usuarios del sistema operativo (servidor):

sprieto, frodriguez, gvisos, jvillena, cuentas humanas de nuestro equipo, con sudo otorgado vía el grupo sgdm_admins, donde nunca se comparten credenciales entre integrantes.

svc_sgdm, usuario de servicio de la aplicación, sin sudo y sin shell interactiva (/sbin/nologin), dueño de /var/www/sgdm.

**ANEP****UTU**DIRECCIÓN GENERAL
DE EDUCACIÓN
TÉCNICO PROFESIONAL

5. Definición de políticas de contraseñas

Se definieron políticas diferentes para las contraseñas de la aplicación del SGDM y para las cuentas del sistema operativo del servidor, debido a que ambas cumplen funciones distintas y, por lo tanto, requieren medidas de seguridad específicas.

En la aplicación del SGDM se establecerá que las contraseñas deberán tener un mínimo de 10 caracteres e incluir letras mayúsculas, minúsculas, números y símbolos. Además, estas se almacenarán utilizando algoritmos de hash seguros, como bcrypt o Argon2, evitando el uso de algoritmos inseguros como MD5 o SHA1. También se define que, cuando un administrador asigne una contraseña a un usuario, éste deberá cambiarla obligatoriamente en su primer inicio de sesión. Asimismo, la cuenta se bloqueará temporalmente luego de cinco intentos fallidos y no será posible reutilizar ninguna de las últimas tres contraseñas utilizadas. Para los roles de Administrador General y Organizador de Torneo, además, se establece que la contraseña deberá renovarse cada 90 días.

En cuanto a las cuentas del sistema operativo del servidor al crear un usuario, el sistema genera automáticamente una contraseña temporal de 12 caracteres mediante openssl rand -base64. Además, el propio sistema operativo almacena dicha contraseña en el archivo /etc/shadow, utilizando SHA-512 como algoritmo por defecto en AlmaLinux. Asimismo, mediante el comando chage -d 0 se obliga al usuario a cambiar esa contraseña en su primer inicio de sesión.

6. Políticas y medidas de seguridad

A partir de las amenazas y vulnerabilidades identificadas anteriormente, se definieron las medidas de seguridad que se aplicarán al proyecto. Estas se organizan en tres áreas principales: la aplicación web, el servidor junto con su infraestructura y las prácticas de trabajo del equipo.

En la aplicación web, se establece que todas las consultas a la base de datos se realizarán mediante sentencias preparadas, las cuales ayudan a prevenir ataques de inyección SQL. Asimismo, los datos ingresados por los usuarios serán validados tanto en el frontend como en el backend, ya que la validación del lado del cliente por sí sola no resulta suficiente. Además, toda la información que se muestre en HTML será escapada correctamente para disminuir el riesgo de ataques XSS.

También se prevé que los formularios encargados de modificar información, como la creación de torneos, la carga de resultados o la administración de usuarios, incorporen tokens anti-CSRF. Del mismo modo, cuando ocurra un error, el sistema mostrará mensajes genéricos al usuario, evitando revelar información interna que pueda comprometer la seguridad de la aplicación.

Con respecto al servidor y la infraestructura, se tiene previsto utilizar un firewall (firewalld) configurado con una política restrictiva, la cual permitirá únicamente los puertos que sean necesarios para el funcionamiento del sistema. Asimismo, se realizarán actualizaciones periódicas del sistema operativo, se implementará la rotación de logs mediante logrotate, se incorporará fail2ban para reforzar la protección frente a intentos de acceso no autorizados y, además, se implementará el uso de SSL/TLS con el objetivo de cifrar las comunicaciones entre los usuarios y el servidor.

Con respecto a la continuidad del servicio, se implementará una política de respaldos, backups periódicos y automatizados tanto de la base de datos como de los archivos de la aplicación, almacenando las copias en una ubicación distinta al servidor de producción y verificando periódicamente que dichas copias puedan restaurarse correctamente.



7. Matriz de análisis de seguridad

Identificamos los activos del sistema, las amenazas que los afectan, las vulnerabilidades asociadas y las medidas de seguridad propuestas.

Activo	Amenaza	Vulnerabilidad	Medida de seguridad
Base de datos (datos personales e información de torneos)	Inyección SQL (SQLi) que borre o altere los resultados	Usuarios sin roles separados en la base de datos	Uso de sentencias preparadas (prepared statements) en todas las consultas a la base de datos
Servidor de la aplicación web e infraestructura	Caída del sistema por Denegación de Servicio (DoS / DDoS)	Recursos de hardware reducidos (1 vCPU, 4GB RAM) y accesos sin protección	Instalación y configuración de Firewall restrictivo y Fail2Ban
Tráfico de red y comunicaciones de usuarios	Manipulación e interceptación de los datos en tránsito	Transmisión de credenciales y puntajes viajando en texto plano	Despliegue de certificados criptográficos bajo el protocolo SSL/TLS
Interfaz del sistema (Navegador del cliente)	Ataques de Cross-Site Scripting (XSS) y robo masivo de sesiones	Carencia de un adecuado escapado de caracteres en las vistas HTML	Implementación de tokens anti-CSRF y escapado estricto de todas las variables
Accesos y perfiles de la plataforma	Uso de credenciales robadas y automatización de bots (Stuffing)	Falta de un límite de intentos permitidos en la ventana de login	Bloqueo temporal del usuario tras alcanzar cinco intentos fallidos en la autenticación